

Nombre: Luis Alberto Vargas Gonzalez

Fecha: 03/12/2025

Actividad y unidad: U8 A Estudio de caso: Delitos informáticos y las legislaciones vigentes

Clase: Criptografía.

Maestría en Ciberseguridad.

Índice.

- 1. Introducción.**
- 2. Acciones por tomar por parte de equipo de TI.**
- 3. Herramientas criptográficas necesarias para responder a este incidente y minimizar daños.**
- 4. Leyes mexicanas que infringe el empleado.**
- 5. Daños y consecuencias legales de y para el Hospital.**
- 6. Conclusiones.**

Introducción.

En este estudio de caso analizaremos desde una perspectiva técnico-legal la y las causas raíces, consecuencias directas e indirectas para el empleado causante del incidente, así como las consecuencias directas e indirectas para el grupo administrativo del Hospital (sin importar si es de ámbito público o privado).

Es además importante denotar que, se tomarán en cuenta diversas vías de solución que puede el departamento de TI tomar, pues como sabemos, existen en el mercado muchas herramientas, software, hardware y programas especializados para complementar o coadyuvar con los requisitos de seguridad para el sector salud.

Además, es importante denotar que, en el ámbito legal, tomaremos en cuenta que la compañía/institución pública que rige el hospital y sus operaciones, así como también sus obligaciones legales están inscritas dentro y solo dentro de la legislación mexicana y en el territorio mexicano, por lo que el uso y cumplimiento de leyes como GDPR, HIPAA no serán tomadas en cuenta para las consecuencias legales que pueda traer tanto para el hospital como para el empleado.

Por último, es importante denotar que, dentro de la triada CIA, los pilares más afectados debido a este incidente son: 1. Integridad, y 2. Confidencialidad pues seguramente el empleado generó una copia de estos datos para publicarlos o venderlos en darknet.

El empleado como pudimos ver si bien, no se especifica que sea un empleado técnico sin embargo en caso de no ser técnico, tiene asesoramiento, que incluso en el caso más extremo es por lo menos un miembro del equipo de TI, por lo que será necesario en una aplicación post-mortem investigar dicha posibilidad

Acciones por tomar por parte de equipo de TI.

Como primera fase de acción por parte del equipo de TI de la organización es necesario hacer lo siguiente:

1. Exploración pasiva y activa de cuentas, usuarios, y sistemas críticos dentro del hospital para evitar una mayor propagación del daño a áreas no involucradas.
2. Cierre parcial del sistema de Base de datos afectado, en donde no podrá acceder ningún empleado fuera del equipo de TI, y directivo del hospital para evitar una mayor filtración de información o de destrucción de esta.
3. Generación de imagen forense (bit a bit) de los servidores afectados y preservación de logs antes de cualquier modificación correctiva, garantizando la **Cadena de Custodia** para que la evidencia sea admisible en el proceso legal bajo el Código Penal Federal.
4. Revocación y renovación de usuarios y contraseñas dentro de dicha base de datos para evitar posibles nuevos vectores de ataque ya sea del mismo empleado que ingresó a esta base de datos.
5. Exploración activa de usuario con el que se ingresó y se borraron los registros de la BD (verificación de privilegios) y revocación de dichos permisos excesivos que permitieron la alteración tan masiva de tantos registros.
6. Creación de backups inmutables y cifrados, lo que ayudará para una posible futura intromisión o hackeo del sistema de base de datos.

Herramientas criptográficas necesarias para responder a este incidente y minimizar daños.

Es necesario aclarar antes que las herramientas criptográficas necesarias para poder proteger el sistema de futuras (mas no de las actuales) incidencias o ciberataques son herramientas aplicadas y no solo conceptos.

Como herramientas podemos citar:

1. Uso de cifrado mixto (Simétrico y Asimétrico) con RSA y AES).
2. Cifrado de discos completos con BitLocker (tanto para pcs personales como para servidores que contengan las BD).
3. Activación de TDE (Cifrado transparente de datos) en el gestor de base de datos que se usen en el Hospital (Oracle, MYSQL, SQL Server).
4. Cifrado a nivel de campo: Software como Axcrypt para identificar que datos son los más sensibles dentro de las BD y evitar cifrar todos los datos y por ende la reducción del ancho de banda de la BD y su rendimiento.
5. Uso de TLS/SSL para datos en tránsito, así como el uso de VPN y protocolos seguros como SSH para poder conectarse remotamente a las sesiones de mantenimiento, actualización de paquetería, y programas.
6. El uso de las firmas digitales Hash nos puede ayudar a tener evidencia irrefutable sobre la autoridad del perpetrador del crimen y asegurar la trazabilidad de las acciones (No Repudio)
7. Uso de módulos de hardware seguro (HSM) para gestionar claves criptográficas, firmas digitales y hashes (muy importante estos últimos para verificar la integridad de los datos).

8. Implementación de un sistema de gestión de llaves (KMS - Key Management System) para asegurar que las llaves de cifrado se almacenen separadas de los datos, rotándolas periódicamente y destruyéndolas de forma segura al final de su vida útil.

Leyes mexicanas que infringe el empleado

Las leyes mexicanas dentro del contexto del cuidado de los datos personales, la tipificación de los delitos informáticos tanto de sus fuentes originales como de sus variantes está contenida dentro de varias leyes mexicanas, pues en este caso, el empleado ha infringido múltiples regulaciones y paquetes legales (legislaciones) tomando en cuenta que dentro de la base de datos existen múltiples secciones y tablas, con sus respectivas filas y columnas es necesario aclarar que se ven implicadas (las primeras de manera indirecta siendo agravantes del mismo delito) las siguientes regulaciones.

- **Código Penal Federal Artículo 211 bis 1. Siendo esta la más importante.**
- Ley Federal de Protección de Datos Personales en Posesión de los Particulares.
- Ley General de Títulos y Operaciones de Crédito.
- Ley de Instituciones de Crédito.

Los delitos que fueron empleados dentro de este incidente fueron:

1. Delito de revelación de secretos.
2. Delito contra la integridad de sistemas informáticos (Sabotaje).
3. Suplantación de identidad (en caso de haber accedido con un usuario de altos privilegios para causar el perjurio).
4. Abuso de confianza: El empleado tenía una relación contractual y legítima con el hospital. Aprovechó esa posición y los recursos

que se le confiaron (la computadora, la red) para causar un perjuicio

Daños y consecuencias legales para el Hospital.

Como primer síntoma de daños causados directa e indirectamente a la organización están las siguientes consecuencias:

1. Daño reputacional de y por clientes finales, competidores, y proveedores por el acceso no autorizado a sus datos confidenciales.
2. Posibles demandas jurídicas por parte de Clientes finales, ya sea de manera individual o colectiva, y proveedores por el incidente.
3. Posibles multas por parte de diversas organizaciones que rijan el sector salud (secretaría de salud, Secretaría de Anticorrupción y buen gobierno).
4. El hospital infringe la **LFPDPPP** no por "cometer el delito", sino por **incumplimiento del deber de seguridad** (Artículo 19 de la LFPDPPP). Al permitir que un empleado enojado tuviera permisos de escritura/borrado sobre *toda* la base de datos (contable, pacientes, etc.), fallaron en implementar las medidas de seguridad administrativas y técnicas necesarias.
5. Obligación de Notificación a Titulares: Conforme al artículo 20 de la LFPDPPP, el hospital podría estar obligado a informar a cada paciente afectado sobre la vulneración, lo cual elevaría exponencialmente los costos operativos y el daño reputacional

Conclusiones.

A manera de conclusión podemos argumentar que:

El análisis de este incidente revela que la seguridad de la información en el sector salud no depende únicamente de la protección contra amenazas externas, sino de la gestión crítica del **riesgo interno**. El borrado deliberado de la base de datos por parte de un empleado con privilegios vigentes expone una falla sistémica en los controles de acceso y en la segregación de funciones, vulnerando directamente los pilares de **Integridad y Disponibilidad** de la información.

Desde una perspectiva legal, es un hecho firme que la conducta del empleado trasciende el ámbito laboral y se tipifica como un **delito federal** bajo el **Artículo 211 bis 1 del Código Penal Federal**, al modificar y destruir información contenida en sistemas protegidos sin autorización. Simultáneamente, el incidente detona una responsabilidad administrativa para el Hospital bajo la **Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP)**, dado que la falta de medidas preventivas (como respaldos inmutables o controles de acceso granulares) evidencia un incumplimiento en el deber de seguridad (Art. 19), exponiendo a la organización a multas severas y daños reputacionales irreversibles.

Finalmente, la implementación de herramientas criptográficas como **TDE (Transparent Data Encryption)**, **HSM** y cifrado de respaldos deja de ser una opción técnica para convertirse en una **obligación de cumplimiento**. La criptografía actúa aquí como el último bastión de defensa: cuando la confianza humana se rompe, las garantías matemáticas de las herramientas de seguridad son lo único que puede asegurar la continuidad operativa y la protección del patrimonio digital de la institución.